Assignment 4. Security, Resilience, and Intrusion Tolerance

Synthetic Kazakhstan University Research Server Incident

Astana IT University | Fault Tolerance | Academic Year 2026-2027

Context note: All operational data in this assignment are synthetic educational data. They are designed to represent a realistic Kazakhstan/Astana university context and do not describe actual AITU infrastructure, incidents, or internal systems.

Scenario

A synthetic research server used by a Kazakhstan university research group has experienced a ransomware-style incident. The task is to analyze the incident, design resilient security controls, and evaluate recovery.

The dataset is fictional and is not an account of an actual Astana IT University or Kazakhstan university cyber incident.

Incident dataset

Time	Event	Source	Severity
09:01	15 failed logins	10.20.4.15	Medium
09:03	21 failed logins	10.20.4.15	High
09:04	Successful login	10.20.4.15	High
09:07	320 files modified	10.20.4.15	Critical
09:08	CPU usage increased to 95%	Research-Server-01	High
09:10	1,200 files encrypted	Research-Server-01	Critical
09:12	Backup deletion attempt	Research-Server-01	Critical
09:13	Outbound connection to unknown IP	Research-Server-01	High
09:15	Database access spike	Research-Server-01	High
09:18	Antivirus disabled	Research-Server-01	Critical

Part A. Incident Analysis (6 points)

Time	Event	Attack stage	Evidence	Risk
09:01	15 failed logins	Reconnaissance	First burst of failed logins from one internal host, probing which accounts exist	Medium
09:03	21 failed logins	Credential attack	21 more failures in 2 minutes from the same host, brute force against one account	High
09:04	Successful login	Privilege compromise	Success right after 36 failures from the same IP, the password was guessed	Critical
09:07	320 files modified	Lateral movement	The workstation 10.20.4.15 now changes files on the research server	Critical
09:08	CPU usage increased to 95%	Data destruction	CPU 95% one minute after mass changes, encryption process running	High

Time	Event	Attack stage	Evidence	Risk
09:10	1,200 files encrypted	Data destruction	1,200 files encrypted, research data unusable	Critical
09:12	Backup deletion attempt	Recovery attack	Attempt to delete backups so the victim cannot restore	Critical
09:13	Outbound connection to unknown IP	Exfiltration	New outbound connection to an unknown address from a server that should not browse	High
09:15	Database access spike	Exfiltration	Database read spike two minutes after the outbound channel opened	High
09:18	Antivirus disabled	Persistence	Antivirus disabled to keep access and hide further tools, which needs admin rights	Critical

The whole attack took 17 minutes. It took 3 minutes and 36 wrong passwords to get into the account, so there was no lockout and no MFA. Encryption started 6 minutes after the login. The attacker went for the backups 5 minutes after the first file change, before taking data out, so blocking recovery was part of the plan from the start. I rated the successful login at 09:04 as Critical although the dataset says High: from that moment every later step was possible.

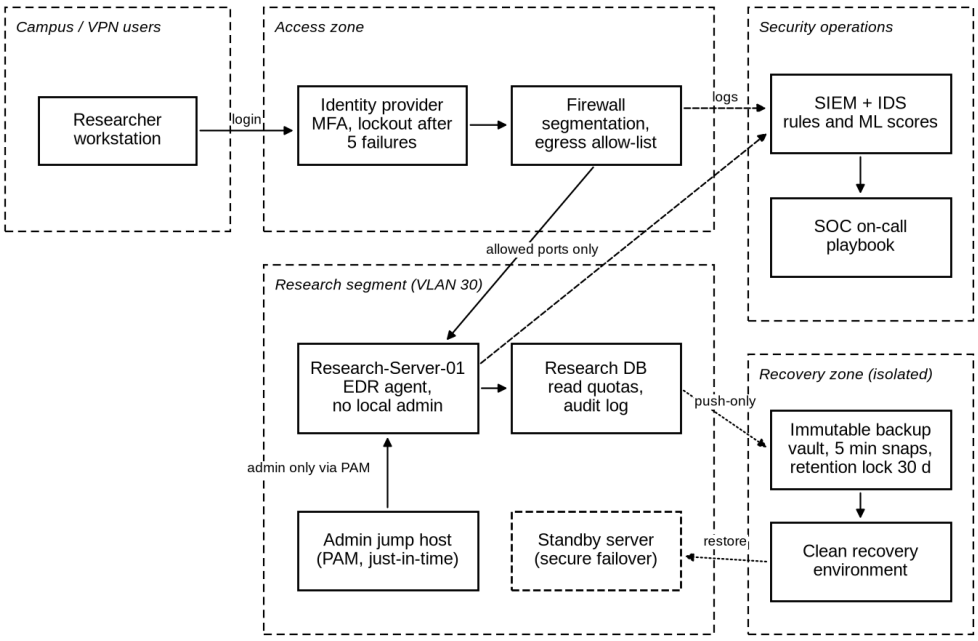
Part B. Risk Matrix (6 points)

Risk = Likelihood x Impact, both on a scale from 1 to 5. Levels: 1 to 4 Low, 5 to 9 Medium, 10 to 16 High, 17 to 25 Critical. At equal score I put first the threat that makes recovery impossible.

Threat	Likelihood	Impact	Risk Score	Priority
Credential compromise	5	4	5 x 4 = 20 (Critical)	2
Ransomware	4	5	4 x 5 = 20 (Critical)	1
Backup destruction	3	5	3 x 5 = 15 (High)	4
Data exfiltration	3	4	3 x 4 = 12 (High)	5
Privilege escalation	4	4	4 x 4 = 16 (High)	3

Threat	Why these values
Ransomware	Observed: 1,200 files encrypted, and the impact is loss of research data
Credential compromise	Observed: 36 guesses were enough, no lockout or MFA stopped it
Privilege escalation	Disabling antivirus needs admin rights, so escalation most likely happened
Backup destruction	Attempted at 09:12 with unknown success, and without backups nothing can be restored
Data exfiltration	Outbound link and DB spike, volume not confirmed, research and personal data at risk

Part C. Resilient Security Architecture (7 points)



Dashed arrows: logs and alerts. Dotted arrows: backup and restore paths. The backup vault accepts new snapshots but cannot be changed or deleted from the research segment.

Figure 1. My security architecture for the research server.

A researcher logs in through the identity provider with MFA, and the account locks after 5 wrong passwords, so the 36 guesses from the dataset would have stopped at the fifth. The firewall lets the workstation reach only the published ports of the research segment, and the segment can open outbound connections only to an allow-list. Admin work goes through a jump host with just-in-time rights, so the user account on the server has no admin rights to disable the antivirus. The server, the database and the firewall send logs to the SIEM, which runs fixed rules and the anomaly scores from Part E and pages the on-call person. Backups go one way into a vault in a separate zone: the server can write new snapshots but cannot change or delete them before the 30-day lock ends. Recovery uses a clean environment and a standby server that the attacker never touched.

Threat	Preventive control	Detection control	Recovery control
Credential attack	MFA on every login, lockout after 5 failures, rate limit per source IP	Alert on more than 10 failures in 5 min from one IP, and a critical alert on a success after many failures	Disable the account, end all sessions, reset the password and MFA
Ransomware	No local admin, application allow-list, EDR, research data on a share with versioning	File change rate rule (more than 100 files per minute), canary files, EDR behaviour alert	Isolate the host, restore the last clean immutable snapshot into the recovery zone
Backup deletion	Vault in a separate admin domain, push-only credentials, retention lock 30 days	Alert on any delete call or retention change on the vault	Use the locked snapshots or the second offline copy
Data exfiltration	Egress allow-list, read quotas on the research database, no direct internet from servers	IDS alert on a new outbound destination, database read volume anomaly	Block the destination, rotate credentials, report to the data owner and the university data protection officer
Privilege escalation	Just-in-time admin through PAM, patching, no shared admin passwords	Alert when a security agent is stopped or a user joins an admin group	Rebuild the server from a clean image, rotate all admin credentials

Part D. Recovery Plan (6 points)

Requirements: RPO at most 5 minutes and RTO at most 30 minutes. I count the RTO from 09:07, the first damage. Steps 3 and 4 run at the same time.

Step	Action	Responsible component	Target time
1	Detect incident: file change rule and score 0.96 for file modifications page the on-call person	SIEM and IDS, SOC on-call	09:09 (2 min)
2	Isolate affected system: EDR network isolation of the server, disable the account, block 10.20.4.15 and the outbound address	EDR, identity provider, firewall	09:12 (3 min)
3	Preserve evidence: memory capture, snapshot of the encrypted disk, export of SIEM logs to write-once storage	EDR, storage, SIEM	09:17 (5 min, parallel with 4)
4	Activate backup: choose the last snapshot before 09:07 (09:05), check its SHA-256 manifest, mount it in the recovery zone	Immutable backup vault	09:17 (5 min)
5	Restore services: start the standby server from a clean image, attach the restored data, replay the database log to 09:06	Standby server, clean recovery environment	09:27 (10 min)
6	Verify integrity: compare SHA-256 with the manifest, database consistency check, malware scan, spot check by the research owner	Recovery environment, research owner	09:31 (4 min)
7	Return to production: switch DNS to the standby, keep the old server isolated for forensics, watch the SIEM for repeat activity	Firewall, DNS, SOC	09:34 (3 min)

RTO: 09:07 to 09:34 is 27 minutes, within 30. RPO: file snapshots every 5 minutes and database log shipping every minute, so the restore point is at most 5 minutes old. In this incident the last clean snapshot is from 09:05, which is 2 minutes of lost work.

I checked the restore part with scripts/recovery_drill.py on 1200 generated files. It replays the dataset: snapshots at 09:00 and 09:05, a researcher edits 10 files at 09:06, 320 changes at 09:07, overwrite of all files at 09:10 and the deletion attempt at 09:12. Results: the change rate rule fired at 09:07, the vault refused both deletions so 2 snapshots were left, 1200 of 1200 files matched SHA-256 after the restore, and the 10 edits made after the snapshot were lost, which is the RPO of 2 minutes in practice. Isolation, evidence, restore and check took 43 ms for 1.09 MB.

The drill also shows two limits of the plan. Between the first mass change at 09:07 and the encryption at 09:10 there are only 3 minutes, so manual isolation at 09:12 is too late to save the files. Only automatic EDR isolation on the alert would save them. And copying data does not scale: at an assumed 200 MB/s, 500 GB of research data needs about 42 minutes just to copy, which is why step 5 mounts the snapshot and uses the standby instead of copying everything back.

Part E. AI-Assisted Detection (5 points)

Assume score >= 0.75 indicates an anomaly.

Event	Normal score	Observed score	Anomaly	Above threshold by
Login failures	0.10	0.81	Yes	0.06

Event	Normal score	Observed score	Anomaly	Above threshold by
File modifications	0.12	0.96	Yes	0.21
CPU usage	0.20	0.88	Yes	0.13
Outbound traffic	0.15	0.79	Yes	0.04
Database requests	0.18	0.91	Yes	0.16

1. Number and rate of detected anomalies: 5 of 5 events have a score of at least 0.75, the rate is 5 / 5 = 100%.
2. Highest-priority event: file modifications. It has the highest score (0.96, 0.21 above the threshold, 8 times its normal value), it is the first strong signal at 09:07, and it is the event that destroys data, so every minute of delay costs more encrypted files.
3. Why AI should complement, not replace, deterministic controls. A score says that something is unusual and leaves the stopping and the restoring to other controls. Outbound traffic is only 0.04 above the threshold, so a small change of the model or the threshold would miss it, while a fixed egress allow-list blocks it every time. The 100% rate is measured on 5 attack signals only. The data has no normal period, so the false alarm rate is unknown. Models can be fooled by a slow attacker and they drift. MFA, lockout, the retention lock and the restore procedure work whatever the score is, and an alert from a fixed rule is easier to explain as evidence.
4. Additional resilience mechanism: a second immutable backup copy in another Kazakhstan data center, for example a university site in another city, with its own admin accounts and a quarterly restore test. It protects against loss of the whole campus site (fire, power, a compromised admin domain), and keeping the copy inside Kazakhstan fits the national rule that personal data must be stored on servers in the country.

Short conclusion

The attacker needed 3 minutes to guess a password and 17 minutes for the whole attack, including an attempt to delete the backups. MFA with lockout would have stopped it at the start. Once the attacker is in, the controls that decide the outcome are automatic isolation on the file change alert and backups that the server cannot delete. My drill showed that locked snapshots survive the deletion attempt and restore all files with verified hashes, with 2 minutes of lost work. On paper the plan meets RPO 5 min and RTO 30 min with 27 min. For large data sets it depends on the standby server, because copying alone would take longer than 30 minutes.

Submission

Completed incident-analysis and risk tables: Parts A and B

Security architecture: Part C, Figure 1

Recovery plan: Part D and results/recovery_drill.log

AI anomaly analysis: Part E

Short conclusion

Oral defense

STUDENT TECHNICAL WORK REPORT / SUBMISSION RECORD

Assignment 4. Security, Resilience, and Intrusion Tolerance

Purpose: This form is a formal submission record. The student must complete every applicable field and attach evidence of their own work. Short generic explanations are not sufficient.

1. Student and Submission Information

Required field	Student entry
Student full name	Alibek Asset
Student ID	255175
Group / cohort	CSE-2503
Instructor	Azamat Serek
Date of submission	12.10.2026
Individual variant / task code assigned by instructor	
Git repository / project link	https://github.com/Gontafi/university-stuff/tree/FTR-assignment-04
Attached code / file names	data/incident.csv, data/anomaly_scores.csv, scripts/analyze.py, scripts/recovery_drill.py, results/analysis.txt, results/analysis.json, results/recovery_drill.log, results/recovery_drill.json, this report

2. Work Period and Task Record

Item	Student entry
Work start date/time	12.10.2026, 14:32
Work completion date/time	12.10.2026, 14:35 (scripts and results committed), report on the same day
Main task completed	Parts A to E: event classification, risk matrix, security architecture, seven-step recovery plan with a recovery drill, anomaly analysis and recommendation
Tools / technologies used	Python 3 standard library (csv, json, hashlib), matplotlib for the diagram, git
Main technical output produced	Analysis script with generated tables, recovery drill log with SHA-256 verification, architecture diagram, recovery plan

3. Report Structure to Complete

For each section below, write the requested evidence in your own words. Include calculations, diagrams, code references, screenshots, logs, or experimental evidence where applicable.

1. Incident Analysis

Classify every incident event into an attack stage, provide evidence from the synthetic dataset, and assess risk.

Required content	Student response / evidence
Summary	Reconnaissance at 09:01, credential attack 09:03, privilege compromise 09:04, lateral movement 09:07, data destruction 09:08 and 09:10, recovery attack 09:12, exfiltration 09:13 and 09:15, persistence 09:18.
Evidence / calculation / artifact reference	Part A table, scripts/analyze.py, results/analysis.txt.
Student-specific decision or observation	I classed 09:07 as lateral movement: the changes come from the workstation 10.20.4.15 and land on the server, and the encryption itself starts at 09:08. The backup attack came before the exfiltration.

2. Risk Matrix

Assign likelihood and impact, calculate Risk = Likelihood x Impact, and justify the resulting priority.

Required content	Student response / evidence
Summary	Ransomware 4 x 5 = 20 and credential compromise 5 x 4 = 20 (Critical), privilege escalation 16, backup destruction 15, data exfiltration 12 (High).
Evidence / calculation / artifact reference	Part B tables with the reason for every value.
Student-specific decision or observation	Credential compromise gets likelihood 5 because it actually happened after only 36 guesses. At equal score ransomware goes first because it makes recovery necessary.

3. Resilient Security Architecture

Design the required architecture containing MFA, segmentation, immutable backup, monitoring, intrusion detection, secure failover, and recovery environment.

Required content	Student response / evidence
Summary	Five zones: users, access zone (MFA, firewall), research segment (server, database, jump host, standby), security operations (SIEM, IDS, on-call), isolated recovery zone (immutable vault, clean environment).
Evidence / calculation / artifact reference	Figure 1 and the control table in Part C.
Student-specific decision or observation	Backups are push-only: the server can add snapshots but has no right to delete them. In the dataset the attacker had the server, so any backup the server could delete would be lost.

4. Recovery Plan

Complete the seven-step recovery plan and show how your target RPO <= 5 minutes and RTO <= 30 minutes are addressed.

Required content	Student response / evidence
Summary	Seven steps from 09:07 to 09:34, RTO 27 min. Snapshots every 5 min give RPO at most 5 min, in this incident 2 min.
Evidence / calculation / artifact reference	Part D table, results/recovery_drill.log: 1200 of 1200 files restored and verified, deletion of both snapshots refused.
Student-specific decision or observation	Manual isolation at 09:12 is too late for the 09:10 encryption. Only automatic isolation on the 09:07 alert saves the files.

5. AI-Assisted Detection

Calculate the anomaly count/rate, identify the highest-priority event, and explain the role and limitations of AI-assisted detection.

Required content	Student response / evidence
Summary	5 of 5 anomalies, 100%. Highest priority: file modifications (0.96).
Evidence / calculation / artifact reference	Part E table, results/analysis.txt (margins and ratios).
Student-specific decision or observation	Outbound traffic passes the threshold by only 0.04. For this signal I rely on the fixed egress allow-list more than on the score.

6. Additional Resilience Recommendation

Recommend one additional resilience mechanism appropriate for the synthetic Kazakhstan university research environment and justify it.

Required content	Student response / evidence
Summary	Second immutable backup copy in another Kazakhstan data center with separate admin accounts and a quarterly restore test.
Evidence / calculation / artifact reference	Part E answer 4. The 09:12 event shows that backups are a target.
Student-specific decision or observation	The copy stays inside Kazakhstan because personal data of students and research participants must be stored in the country.

4. Individual Work and Anti-Plagiarism Record

Because the assignment uses a common educational scenario and dataset, the submitted report must contain verifiable evidence of the individual student's work. Copying another student's wording, calculations, architecture, code, logs, screenshots, or conclusions is not acceptable.

Use your own threat/control mapping rather than copying another student's table wording.

Tie each risk score to your own justification.

Provide a unique architecture diagram and explain its control flow.

Record the exact source file/version used for your analysis.

Be prepared to defend why one control is preventive, detective, or recovery-oriented.

Individual evidence	Student entry
My unique technical decision	Push-only backup vault with a 30-day lock, and automatic EDR isolation on the file change alert, because the dataset leaves only 3 minutes between the first mass change and the encryption.
My own implementation / calculation evidence	scripts/analyze.py produces the Part A, B and E tables from the dataset, and scripts/recovery_drill.py checks the restore step. Both were written and run by me on 12.10.2026.
Exact file, code, commit, notebook, or log reference	Branch FTR-assignment-04, commit c23273d. data/incident.csv, results/analysis.txt, results/recovery_drill.log.

Individual evidence	Student entry
One problem I personally encountered and how I solved it	The first drill run crashed with PermissionError when it prepared the restored files: the copy took over the read-only mode of the locked snapshot. I added a step that makes the restored copy writable. In a real recovery this is the same: data restored from a write-once store has to get normal permissions before production.
One limitation of my own solution	The drill runs on 1,200 small generated files and follows the incident clock. The anomaly scores come from the task. Likelihood and impact are my own judgement.
Preventive, detective or recovery control	The immutable backup is a recovery control: it does not stop encryption and does not raise an alert, it only makes the restore possible. MFA is preventive, the file change rule is detective.

5. Evidence Checklist

Evidence	Included	Where
Completed required tables and calculations	Yes	Parts A, B, D, E
Architecture / RBD / FTA / security diagram	Yes	Figure 1
Source code or configuration files	Yes	Branch FTR-assignment-04, scripts/
Execution logs / experiment results	Yes	results/analysis.txt, results/recovery_drill.log
Screenshots or other reproducible evidence	Yes	README commands rebuild every table
Links to code, datasets, notebooks, or artifacts	Yes	Section 1 of this form
Before/after comparison	Yes	Drill: encrypted files before, verified restore after
Final technical conclusion	Yes	Short conclusion

6. Student Declaration

I confirm that this report describes my own work. I have not copied another student's report, code, calculations, diagrams, logs, screenshots, or conclusions. Any external source or reused material has been identified. I understand that I may be asked to reproduce or explain any part of this submission during the oral defense.

Role	Name	Signature	Date
Student / Executor	Alibek Asset		12.10.2026
Instructor / Accepted by	Azamat Serek		

7. Instructor Acceptance Record

Check	Status / comment
Report structure completed	Yes No Comment:
Evidence is sufficient	Yes No Comment:
Individual contribution is identifiable	Yes No Comment:
Oral defense completed	Yes No Comment:

Check	Status / comment
Final status	Accepted Revision required